

Penetration Testing Style Report

Target: OWASP Juice Shop (localhost:3000) — Legal Practice Environment

Tester: [Lochna Makarand Sabnis]

Date: [29-September-2006]

1. Executive Summary

This report documents a controlled security assessment performed on OWASP Juice Shop, an intentionally vulnerable web application used for ethical hacking practice. The assessment identified multiple critical and high-risk vulnerabilities, including SQL injection, cross-site scripting (XSS), and insecure session cookie configuration. These findings, if present in a real production system, could lead to full account takeover and data compromise.

2. Scope

- Target: OWASP Juice Shop, running locally via Docker (localhost:3000)
- Testing performed manually through the browser and Firefox Developer Tools
- No automated scanning tools used beyond nmap (Task 1.4) for initial reconnaissance

3. Methodology

Testing followed a basic manual approach:

- Reviewed login functionality for injection vulnerabilities
- Tested input fields (search bar) for script injection (XSS)
- Inspected session cookies via browser DevTools for security flag misconfigurations

This mirrors real-world web app penetration testing at a foundational level.

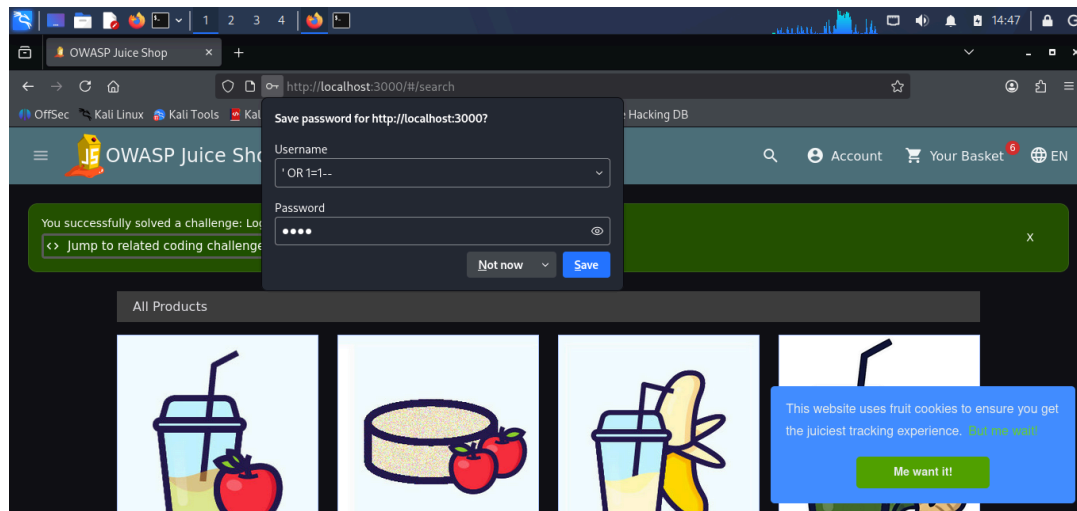
4. Findings

4.1 SQL Injection – Authentication Bypass (Critical)

Description: The login form's email field accepted ' OR 1=1-- as input, which manipulated the backend SQL query to always evaluate as true, bypassing authentication entirely without valid credentials.

Impact: Complete authentication bypass; attacker gains account access (including admin-level access) without any valid password.

Evidence:

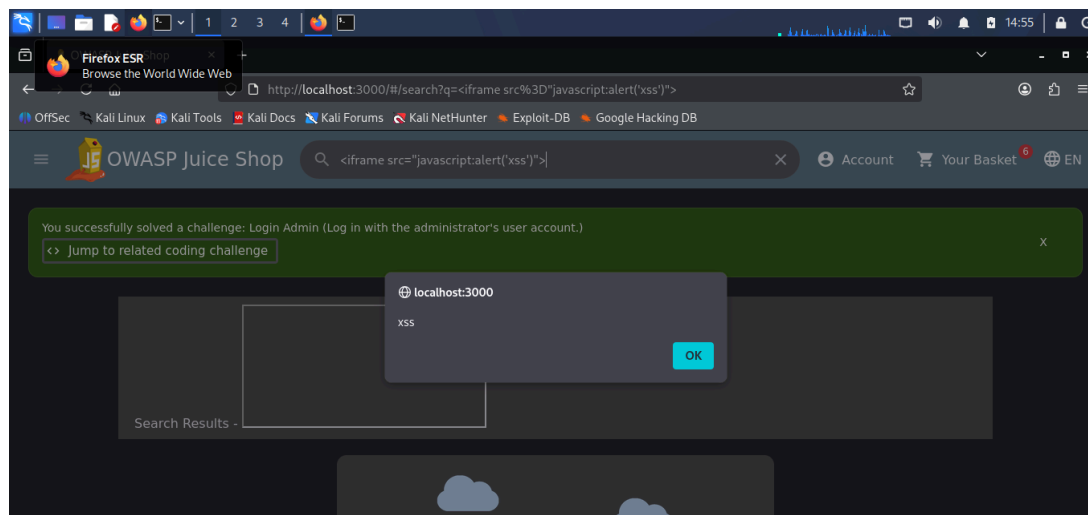


4.2 Cross-Site Scripting (XSS) – Search Field (High)

Description: The search field rendered an `<iframe src="javascript:alert('xss')">` payload without sanitization, executing arbitrary JavaScript in the browser.

Impact: An attacker could use this to steal session data, redirect users to phishing pages, or perform actions on a victim's behalf.

Evidence:

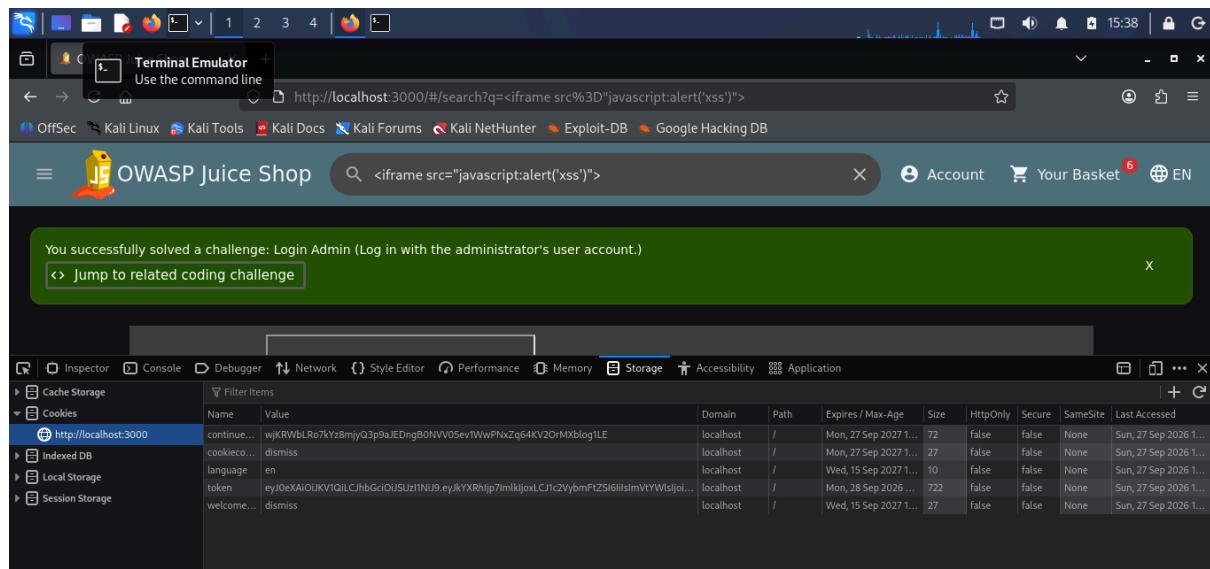


4.3 Insecure Session Cookie Configuration (High)

Description: The session token cookie (a JWT) was found with `HttpOnly: false`, `Secure: false`, and `SameSite: None`.

Impact: Combined with the XSS finding above, this significantly increases risk - a script injected via XSS could read and exfiltrate the session token, leading to session hijacking without needing the SQL injection bypass at all.

Evidence:



5. Risk Summary Table

Finding	Severity	Likelihood	Impact
SQL Injection (Auth Bypass)	Critical	High	Severe
XSS (Search Field)	High	Medium	High
Insecure Session Cookie Config	High	Medium	High

6. Recommendations

- Use parameterized queries / prepared statements to prevent SQL injection
- Sanitize and encode all user input before rendering it in the DOM to prevent XSS
- Set HttpOnly, Secure, and SameSite=Strict/Lax flags on all session cookies
- Implement regular input validation testing as part of the development lifecycle

7. Conclusion

This assessment confirmed several critical vulnerabilities common in the OWASP Top 10 (Injection, XSS, and security misconfiguration). While Juice Shop is intentionally vulnerable for training, these exact patterns are frequently found in real-world applications, making this exercise directly relevant to identifying and mitigating similar risks in production systems.